



Teoria R3 · Autenticació, autorització i middleware

Conceptes clau per protegir les teues aplicacions web de manera correcta, robusta i demostrable. Prepara't per a **R3M5**.

DAW · REPTE R3

Dos conceptes, dues preguntes

Autenticació

Qui ets?

Verificar la identitat de l'usuari: credencials, sessió, token.
Sense autenticació, l'aplicació no sap amb qui parla.

Autorització

Què pots fer?

Un cop identificat, decidir quines accions o recursos té permès usar. Ser autenticat no implica tenir tots els permisos.

 L'ordre és sempre el mateix: primer autenticar, després autoritzar.

El gran error: proteger la vista, no la ruta



✗ Protecció visual (insuficient)

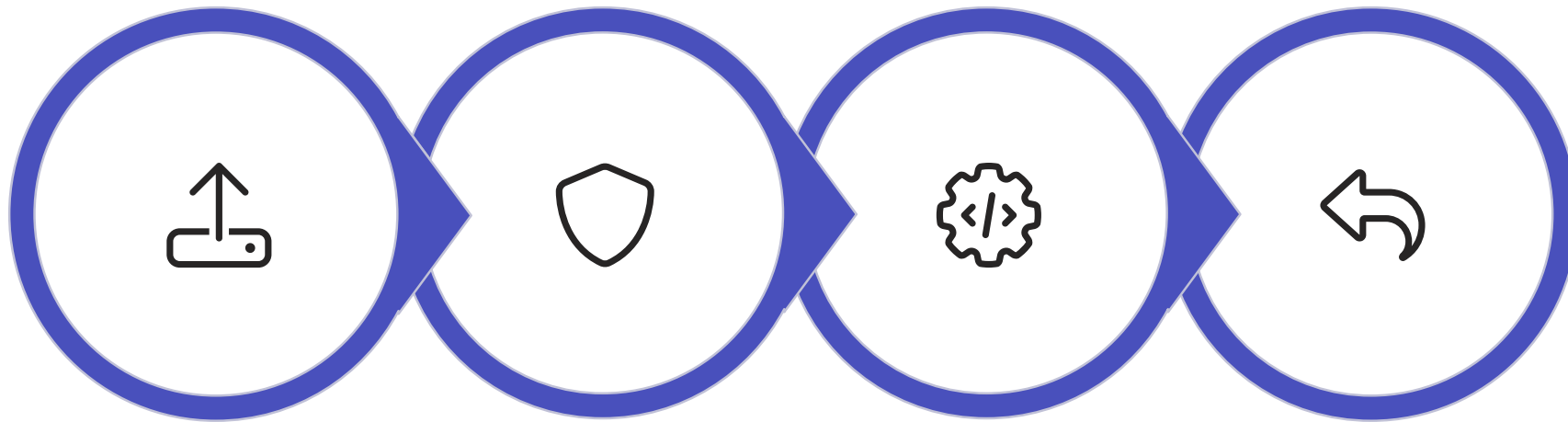
Amagar un botó o un menú amb CSS o JavaScript **no protegeix res**. Qualsevol usuari pot accedir directament a la URL o fer una petició manual.

✓ Protecció de ruta (correcta)

La verificació ha d'estar en el **servidor**. Si la ruta no comprova qui fa la petició, el recurs és públic independentment del que mostri la interfície.

⊗ Ocultar ≠ Protegir. El control real és sempre al backend.

Flux d'una petició protegida



Petició

Middleware

Controlador

Resposta

El middleware o guard intercepta la petició **abans** d'arribar al controlador. Si la verificació falla, la resposta és un `403` o una redirecció — mai s'executa la lògica de negoci.

Mecanismes de protecció per stack

Cada framework té la seua nomenclatura, però tots implementen el mateix patró: interceptar, verificar i decidir.



Equivalències entre stacks

Necessitat	Laravel	Symfony	NestJS
Autenticació	guard / session / auth scaffolding	security / firewall	guard / strategy
Protecció de ruta	middleware	access control	guard / middleware / decorator
Autorització	policy / gate	voter	guard / decorator / service
Usuari demo	seeder / factory	fixture	seed script
Cas denegat	403 / redirect	403 / redirect	403 / exception filter

Checklist de prova: els quatre escenaris

Per demostrar que la protecció funciona correctament, cal provar **tots quatre casos** com a evidència del repte.

1

Sense autenticar

Accedir a la ruta protegida sense sessió. Ha de redirigir al login o retornar 401.

2

Cas autoritzat

Iniciar sessió amb l'usuari correcte. Ha de poder accedir al recurs sense errors.

3

Cas denegat

Iniciar sessió amb un usuari sense permisos. Ha de rebre un 403 o ser redirigit.

4

Logout

Tancar sessió i intentar accedir de nou. La protecció ha de seguir activa.



El cas denegat és una evidència **obligatòria**. Sense ell, no es pot demostrar que la protecció funciona.

Errors habituals a evitar

Credencials personals en el codi

Les dades demo (usuaris, contrasenyes) han de ser **fictícies** i generades per seeders o fixtures. Mai dades reals ni contrasenyes personals al repositori.

Protecció només al frontend

Ocultar botons, rutes o seccions amb JavaScript no substitueix la validació al servidor. Sempre cal middleware o guard al backend.

Confondre autenticació amb autorització

Verificar que l'usuari existeix (autenticació) no implica que tinga permís per a l'acció concreta (autorització). Ambdues capes són necessàries.

Preguntes de comprovació

Respon aquestes preguntes per verificar que el teu projecte implementa la protecció correctament:

- Qui és l'usuari autenticat en el teu projecte? Com s'ha creat (seeder, fixture, seed)?
- Quina acció o ruta concreta queda protegida en servidor?
- Quin mecanisme usa el teu stack: middleware, guard, voter, policy o equivalent?
- Com proves i documentes el cas autoritzat i el cas denegat?
- Per què ocultar un botó no és suficient per protegir un recurs?